

A
Report on

PRACTICAL SECURITY ASSESSMENT (TASK 7)

Submitted In Partial Fulfillment of the Requirements

for the

Cyber Security Internship (Week 2) (VAPT)

Internship Organization



CyArt Tech LLP

Submitted by

HARSH JHA

B.Tech in CSE (2203330100073)

Raj Kumar Goel Institute of Technology and Management, Ghaziabad



Submission Date: 27 March 2026



LIST OF FIGURES

CHAPTER NO.	TITLE	PAGE NO.
1	Figure 1 : Vapt flow diagram	2
2	Figure 2: Network scanning using nmap	2
3	Figure 3: Authenticated vs Unauthenticated Scanning	3
4	Figure 4: Measure the severity of vulnerabilities	4
5	Figure 5: CVSS Vulnerability Scoring System	5
6	Figure 6 : Penetration Testing Lifecycle	5
7	Figure 7: Reconnaissance using Shodan	6
8	Figure 8: Exploitation using Metasploit Framework	6
9	Figure 9: Web Application Scanning using nikto	8
10	Figure 10: SQL Injection Attack on DVWA	9
11	Figure 11: Cross-Site Scripting (XSS) Attack in DVWA	9
12	Figure 12: Mitigation Techniques	11
13	Figure 13: Exploit Development Process	11



TABLE OF CONTENTS

CHAPTER NO.	TITLE	PAGE NO.
	LIST OF FIGURES	i
	TABLE OF CONTENTS	ii
1.	INTRODUCTION	
	1.1 OVERVIEW	1
	1.2 PURPOSE OF THIS TASK	1
	1.3 TARGET INFORMATION	1
	1.4 OBJECTIVES	2
2.	VULNERABILITY SCANNING TECHNIQUES	
	2.1 OVERVIEW	2
	2.2 TYPES OF SCANNING	3
	2.3 VULNERABILITY SCORING (CVSS V4.0)	4
	2.4 FALSE POSITIVES	4
	2.5 KEY OBJECTIVES	4-6
3.	PENETRATION TESTING TECHNIQUES	
	3.1 OVERVIEW	7
	3.2 PHASES OF PENETRATION TESTING	7
	3.3 METHODOLOGIES	7
	3.4 ETHICAL CONSIDERATIONS	7-8
	3.5 KEY OBJECTIVES	8-9
4.	AUTOMATION AND NETWORK DIAGRAM	
	4.1 OVERVIEW	10
	4.2 TYPES OF EXPLOITS	10
	4.3 EXPLOIT DEVELOPMENT PROCESS	10
	4.4 MITIGATION TECHNIQUES	11
	4.5 KEY OBJECTIVES	11
5.	CONCLUSION AND REFERENCE	
	5.1 CONCLUSION	12
	5.2 REFERENCE	12

1. INTRODUCTION

1.1 Overview

Vulnerability Assessment and Penetration Testing (VAPT) is a comprehensive cybersecurity process used to identify, analyze, and mitigate vulnerabilities in systems, networks, and applications. It combines automated scanning tools with manual testing techniques to simulate real-world cyberattacks.

In today's digital environment, organizations rely heavily on IT infrastructure, making them vulnerable to cyber threats. VAPT helps in detecting security weaknesses before attackers exploit them, thereby strengthening the overall security posture.

1.2 Purpose of This Task

The main purpose of this task is to perform a security assessment of a target system using VAPT techniques. This includes identifying vulnerabilities, analyzing risks, and suggesting appropriate mitigation strategies.

This task also aims to provide practical exposure to cybersecurity tools and methodologies used in real-world scenarios.

1.3 Target Information

The target system used in this assessment is a vulnerable virtual machine configured in a controlled lab environment.

Target System: Metasploitable / Test Machine

Attacker Machine: Kali Linux

Network Type: Virtual Network (NAT/Host-only)

Tools Used: Nmap, Nikto, Metasploit

1.4 Objectives

- Identify vulnerabilities in the system
- Analyze security risks
- Perform penetration testing
- Suggest mitigation techniques
- Improve overall system security

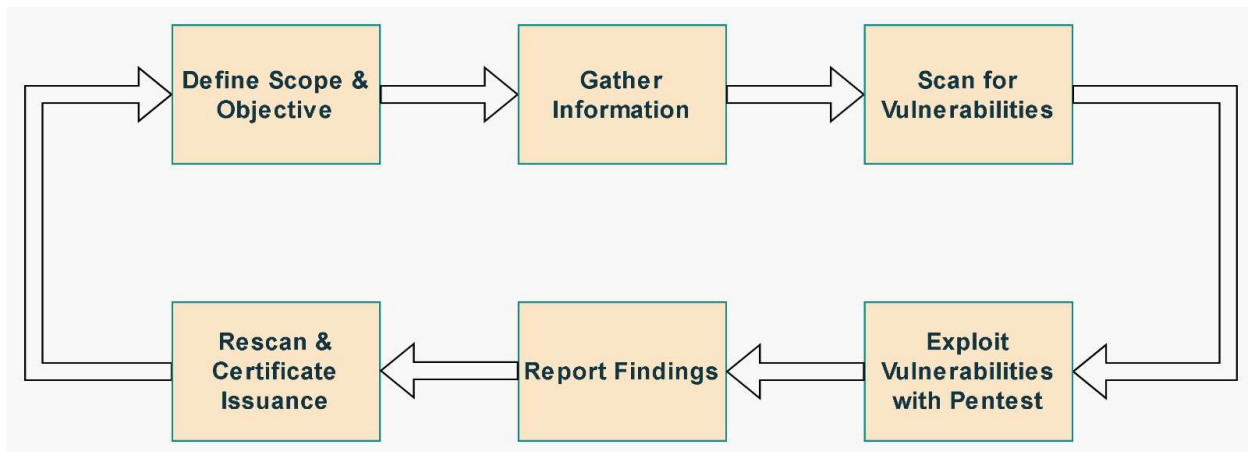
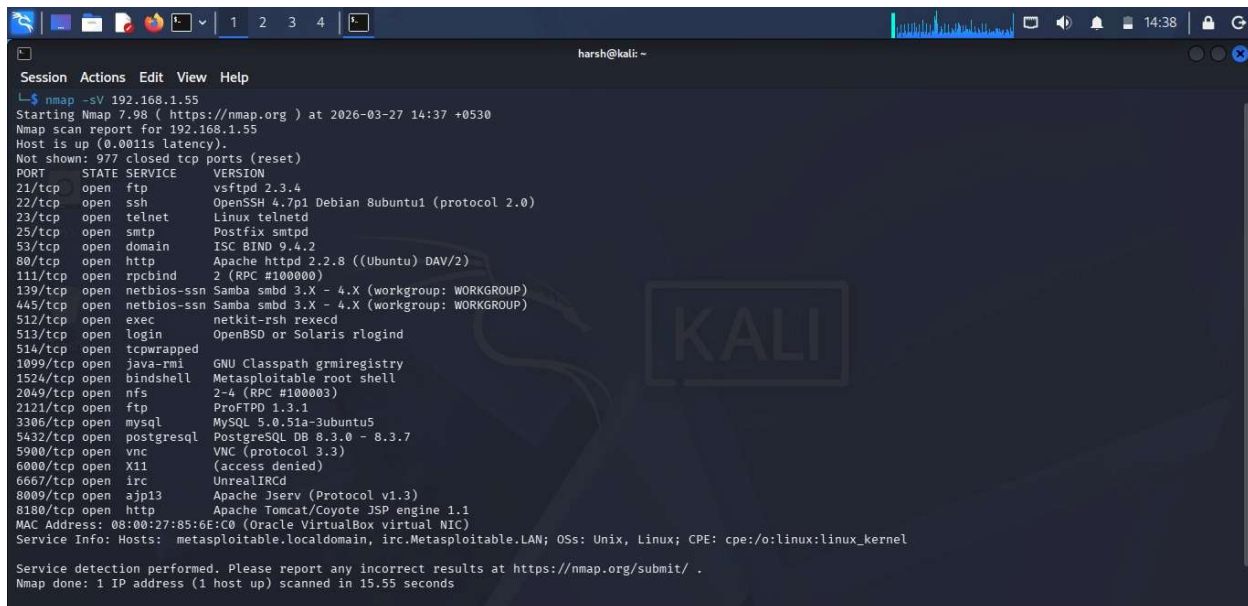


Figure 1: Vapt flow diagram



```

Session Actions Edit View Help
L$ nmap -sV 192.168.1.55
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-27 14:37 +0530
Nmap scan report for 192.168.1.55
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:85:6E:C0 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.55 seconds
  
```

Figure 2: Network scanning using nmap

2. VULNERABILITY SCANNING TECHNIQUES

2.1 Overview

Vulnerability scanning is an automated process used to detect known security weaknesses in a system. It helps in early identification of vulnerabilities and reduces the risk of exploitation.

2.2 Types of Scanning

1. Network Scanning

- Network scanning involves identifying active devices, open ports, and running services within a network.
- Tool Used: Nmap
- Example: Detecting open ports such as
 - Port 21 (FTP)
 - Port 22 (SSH)
 - Port 80 (HTTP)

2. Application Scanning

- Application scanning focuses on detecting vulnerabilities in web applications.
- Tool Used: Nikto
- It detects:
 - Outdated software
 - Server misconfigurations
 - Security vulnerabilities

Type	Description
Authenticated	Uses login credentials for deep scanning
Unauthenticated	Simulates an external attacker

Figure 3: Authenticated vs Unauthenticated Scanning

2.3 Vulnerability Scoring (CVSS v4.0)

The Common Vulnerability Scoring System (CVSS) is used to measure the severity of vulnerabilities.

Score Range	Severity Level
0.0 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

Figure 4: Measure the severity of vulnerabilities

Example:

The WannaCry ransomware attack exploited a critical SMB vulnerability, causing widespread global damage.

2.4 False Positives

False positives occur when a vulnerability scanner incorrectly reports a vulnerability that does not actually exist. These must be manually verified to ensure accuracy.

2.5 Key Objectives

- Identify vulnerabilities
- Assess risk levels
- Prioritize fixes
- Improve security posture



CVSS RATING	
CVSS SCORE	QUALITATIVE RATING
0.0	None
0.1 - 3.9	Low
4.0 - 6.9	Medium
7.0 - 8.9	High
9.0 - 10.0	Critical

Figure 5: CVSS Vulnerability Scoring System

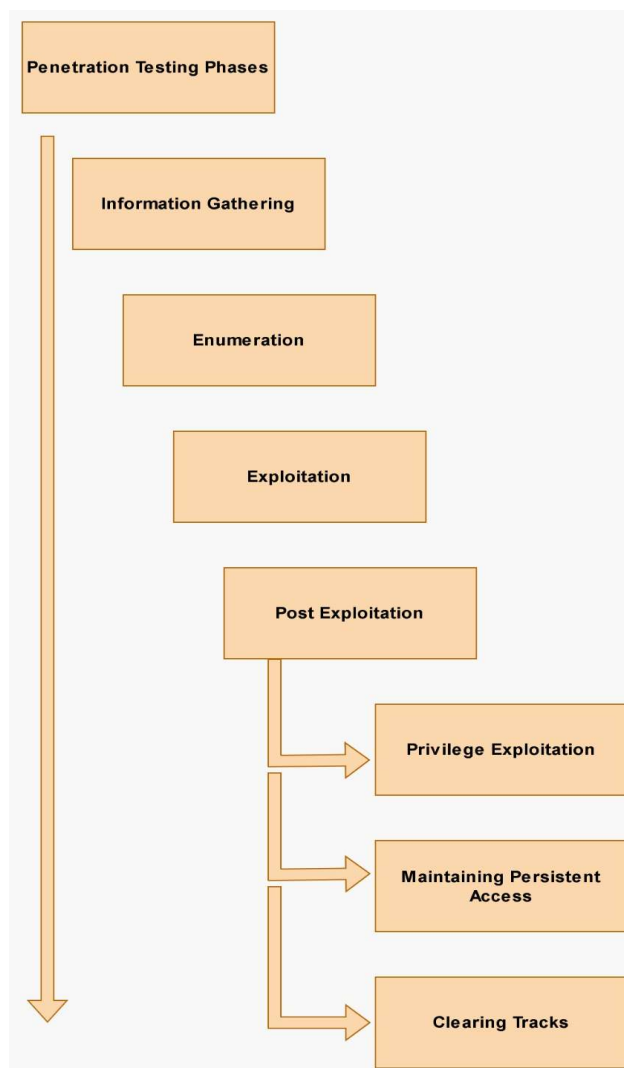


Figure 6: Penetration Testing Lifecycle

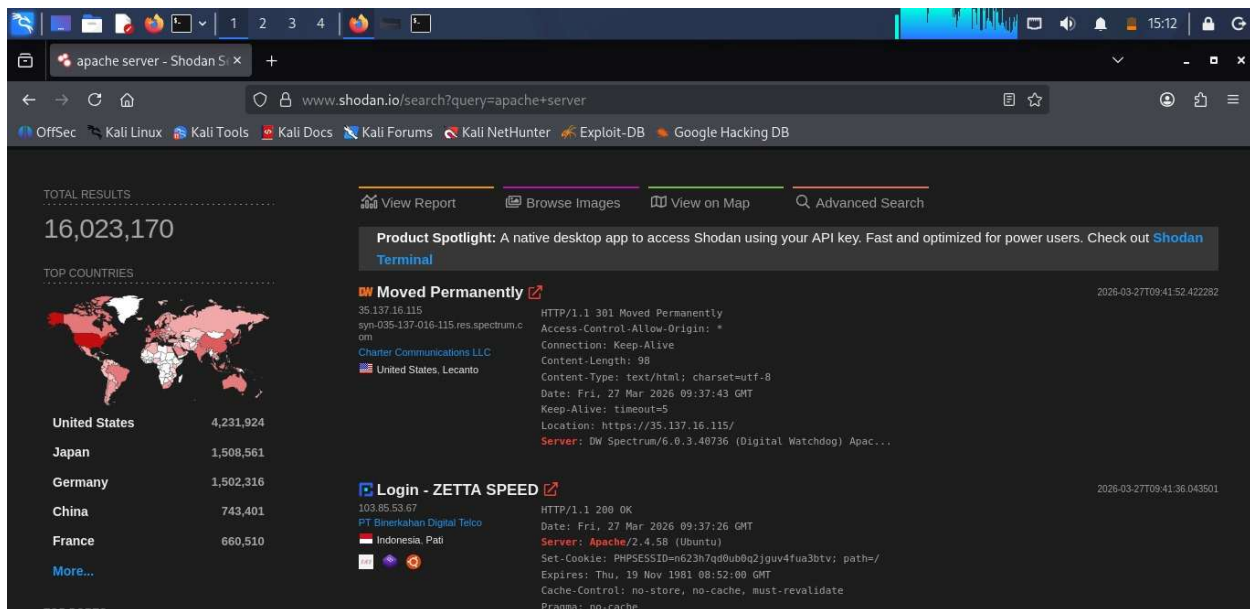


Figure 7: Reconnaissance using Shodan

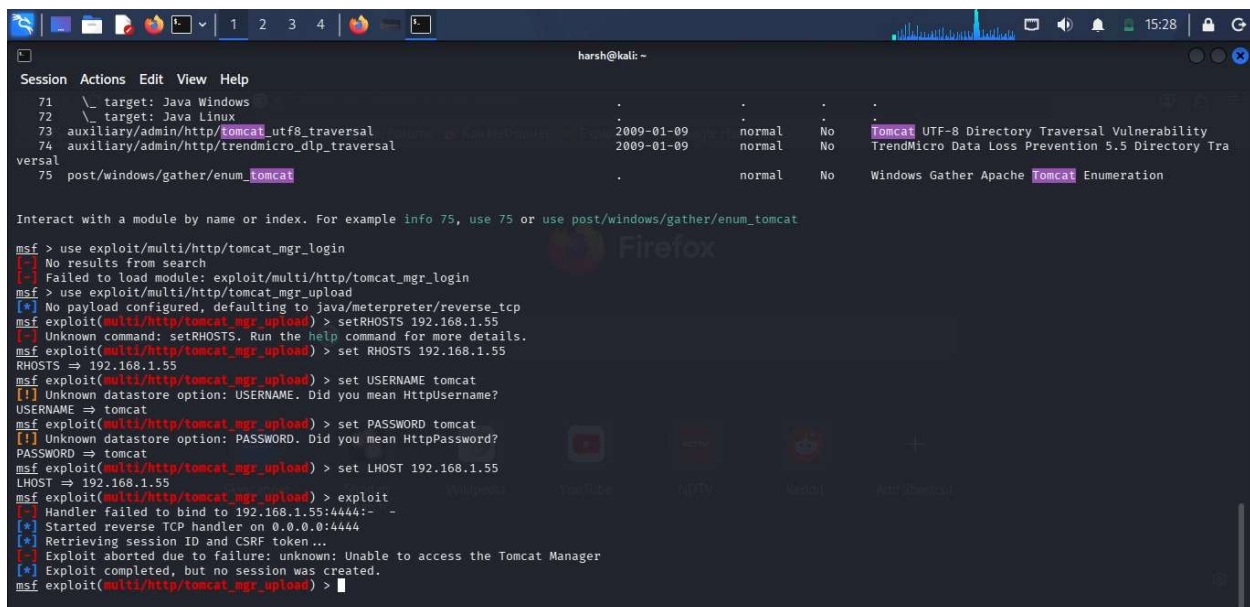


Figure 8: Exploitation using Metasploit Framework

3. PENETRATION TESTING TECHNIQUES

3.1 Overview

Penetration testing is a simulated cyberattack performed to evaluate the security of a system by exploiting identified vulnerabilities.

3.2 Phases of Penetration Testing

1. Reconnaissance

Information gathering about the target system.

Tool: Shodan

2. Scanning

Identifying vulnerabilities using automated tools.

Tools: Nmap, Nessus

3. Exploitation

Attempting to exploit vulnerabilities.

Tool: Metasploit

4. Post-Exploitation

Maintaining access and extracting sensitive information.

5. Reporting

Documenting findings, risks, and recommendations.

3.3 Methodologies

- PTES (Penetration Testing Execution Standard)
- OWASP WSTG (Web Security Testing Guide)

These provide structured guidelines for performing penetration testing.

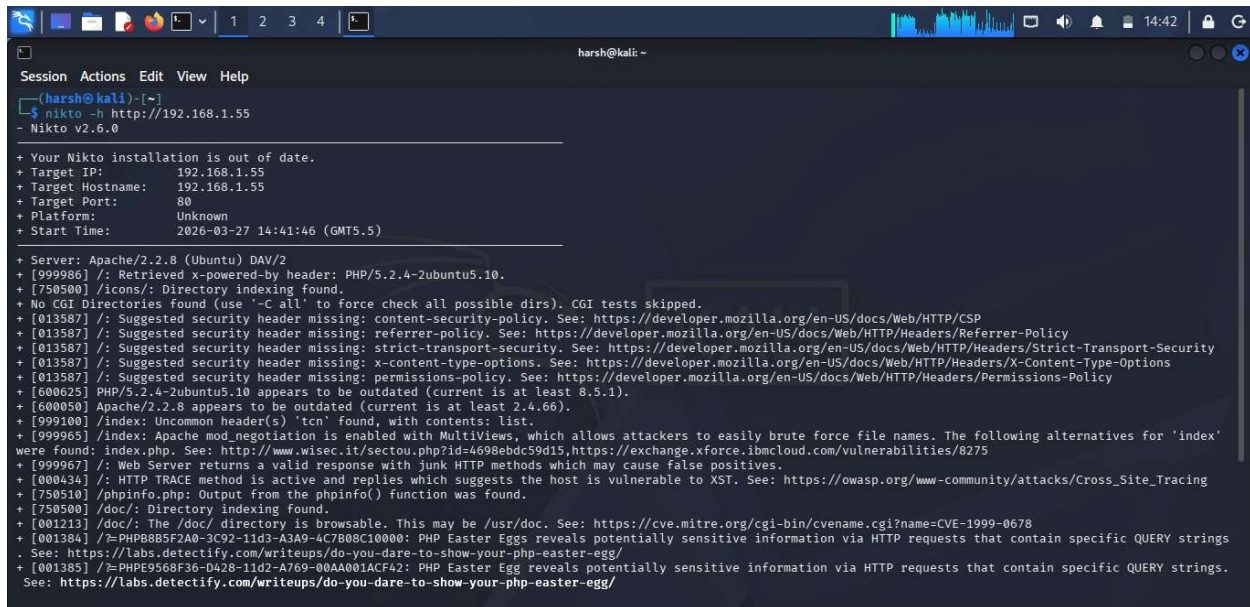
3.4 Ethical Considerations

- Obtain proper authorization

- Follow defined scope
- Avoid system damage
- Maintain confidentiality

3.5 Key Objectives

- Simulate real-world attacks
- Identify critical vulnerabilities
- Strengthen system defenses



```

harsh@kali: ~
Session Actions Edit View Help
(harsh@kali)~$ nikto -h http://192.168.1.55
- Nikto v2.6.0

+ Your Nikto installation is out of date.
+ Target IP: 192.168.1.55
+ Target Hostname: 192.168.1.55
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-03-27 14:41:46 (GMT+5.5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [090100] /index: Uncommon header(s) 'tcn' found, with contents: List.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?PHPBB885F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?PHPE9508F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
  
```

Figure 9: Web Application Scanning using nikto



```
harsh@kali:~$ sqlmap -u "http://192.168.1.55/dvwa/vulnerabilities/sqli/?id=18Submit=Submit" --cookie="security=low; PHPSESSID=xyz" --dbs

[1] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:37:07 /2026-03-27/

[15:37:07] [INFO] testing connection to the target URL
got a 302 redirect to 'http://192.168.1.55/dvwa/login.php'. Do you want to follow? [Y/n] y
[15:37:17] [INFO] checking if the target is protected by some kind of WAF/IPS
[15:37:17] [INFO] testing if the target URL content is stable
[15:37:17] [WARNING] GET parameter 'id' does not appear to be dynamic
[15:37:17] [WARNING] heuristic (basic) test shows that GET parameter 'id' might not be injectable
[15:37:18] [INFO] testing for SQL injection on GET parameter 'id'
[15:37:18] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[15:37:19] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[15:37:19] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[15:37:19] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[15:37:20] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[15:37:20] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[15:37:21] [INFO] testing 'Generic inline queries'
[15:37:21] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[15:37:21] [WARNING] time-based comparison requires larger statistical model, please wait. (done)
[15:37:22] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[15:37:22] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[15:37:22] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
```

Figure 10: SQL Injection Attack on DVWA

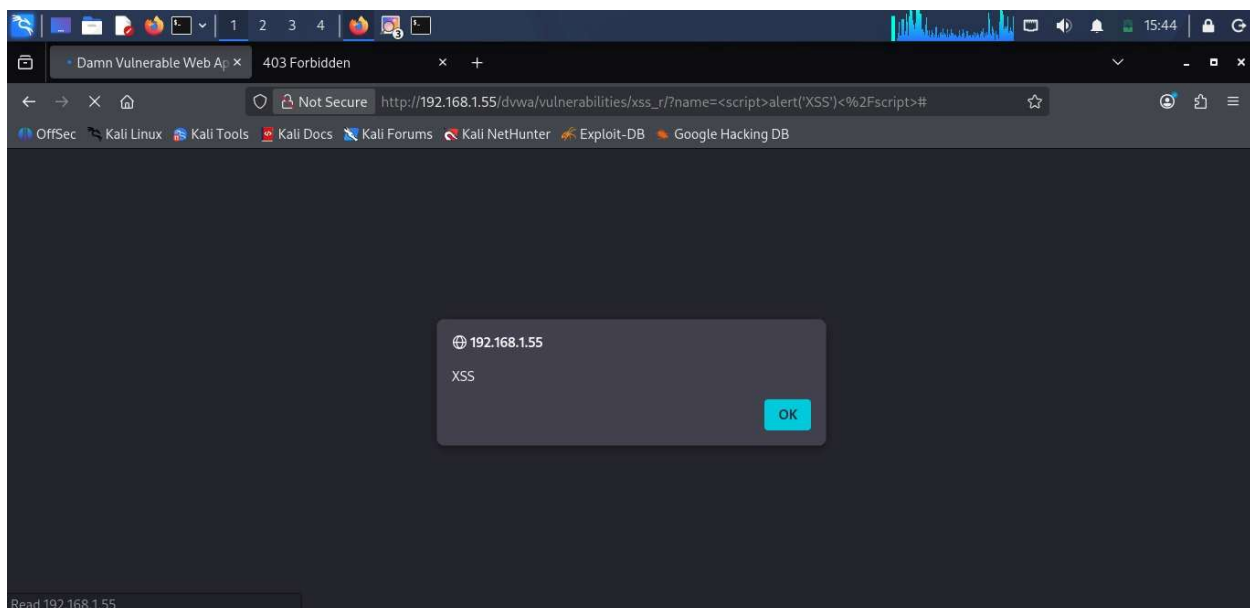


Figure 11: Cross-Site Scripting (XSS) Attack in DVWA

4. EXPLOIT DEVELOPMENT BASICS

4.1 Overview

Exploit development involves creating code that takes advantage of vulnerabilities to gain unauthorized access or perform malicious actions.

4.2 Types of Exploits

Buffer Overflow

Occurs when excess data overwrites memory, leading to system compromise.

SQL Injection

Allows attackers to manipulate database queries.

Example: ' OR 1=1 –

Cross-Site Scripting (XSS)

Allows injection of malicious scripts into web pages.

Example: `<script>alert("Hacked")</script>`

4.3 Exploit Development Process

- Identify vulnerability
- Analyze system behavior
- Develop Proof of Concept (PoC)
- Test in a controlled environment

4.4 Mitigation Techniques

Technique	Description
ASLR	Randomizes memory locations
WAF	Filters malicious traffic
Patching	Fixes vulnerabilities

Figure 12: Mitigation Techniques

4.5 Key Objectives

- Understand attack techniques
- Develop safe testing methods
- Improve application security

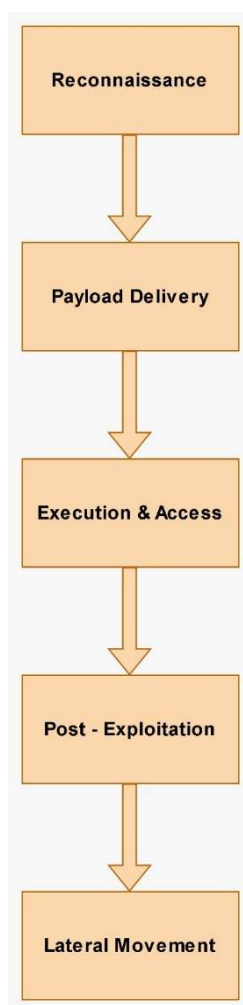


Figure 13: Exploit Development Process

5. CONCLUSION AND REFERENCE

5.1. Conclusion

Vulnerability Assessment and Penetration Testing (VAPT) is an essential cybersecurity practice that helps organizations identify and fix security weaknesses before attackers exploit them.

By combining automated scanning and manual testing, organizations can build a strong defense against cyber threats. Regular testing and continuous monitoring are necessary to maintain a secure environment.

5.2 References

OWASP Testing Guide

NIST SP 800-115

PTES Framework

Exploit-DB

TryHackMe